

Annexe technique

Protocole inter-wallets

Spécification consolidée — Flux de validation Wallet B

Objet de ce document

Ce document consolide l'ensemble des éléments fragmentés du cahier des charges concernant le protocole inter-wallets. Il ajoute les spécifications manquantes : séquence ordonnée de traitement côté Wallet B, comportement explicite en cas de statut REVIEW, et clarification des responsabilités entre émetteur et récepteur.

Il constitue une annexe autonome, destinée à être lue conjointement avec les sections 3, 4, 6, 7 et les annexes A–B du cahier des charges principal.

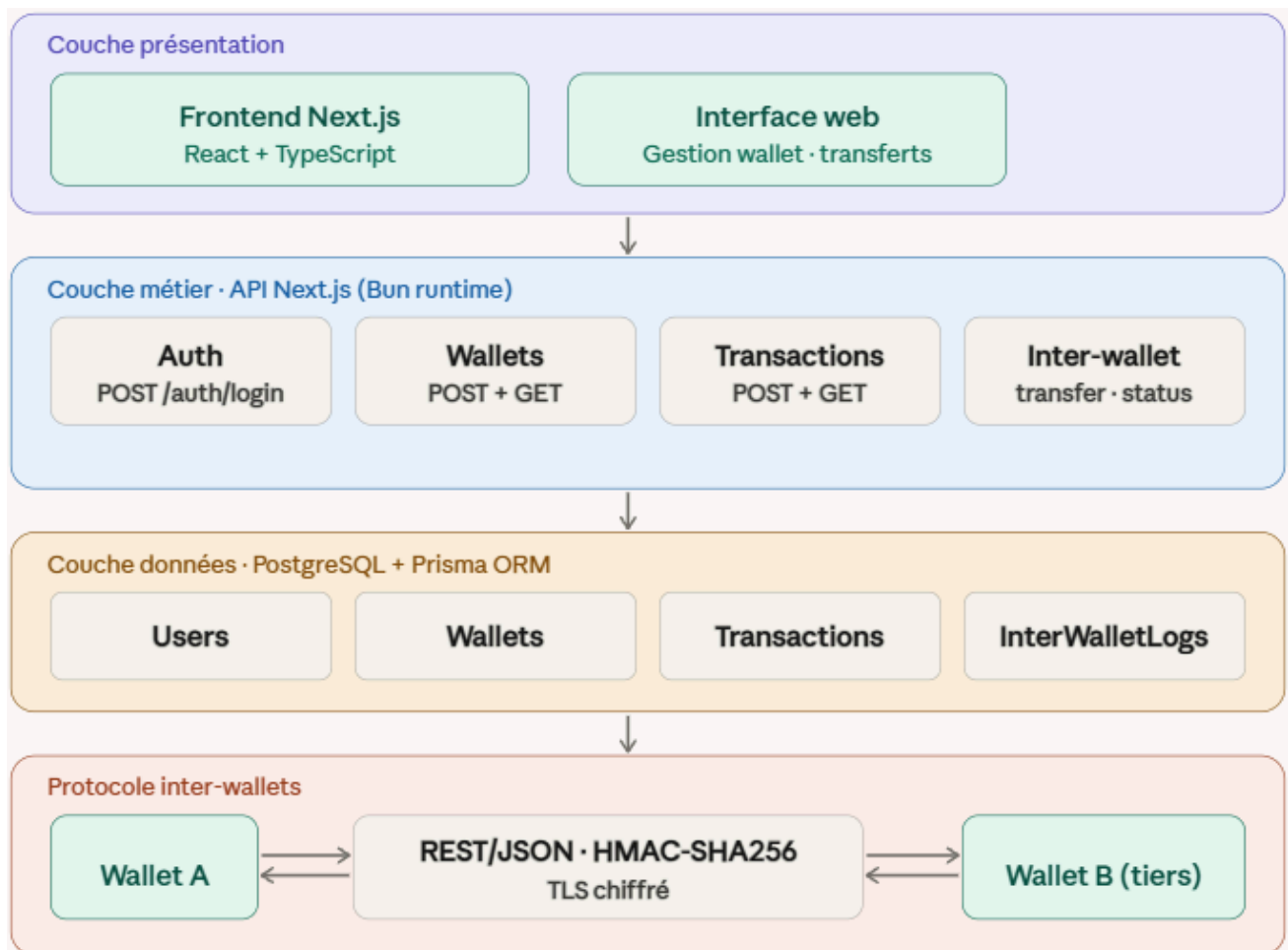
1. Flux de validation côté Wallet B

Cette section formalise la séquence complète de traitement d'une transaction entrante. L'ordre des étapes est contractuel : toute implémentation doit le respecter strictement.

Règle fondamentale

La validation de la signature HMAC-SHA256 est TOUJOURS exécutée en premier, avant toute analyse de fraude et avant tout accès à la base de données. Un payload dont la signature est invalide est rejeté immédiatement avec un HTTP 401, sans trace en base.

0.0 Vue d'ensemble



1.1 Tableau de séquence

Le tableau ci-dessous décrit chaque étape, les acteurs impliqués et le résultat attendu. Les étapes 4a/4b et 5a/5b/5c sont mutuellement exclusives.

Éta pe	Wallet A (émetteur)	Réseau / TLS	Wallet B (récepteur)	Résultat attendu
1	Génère transaction_id (UUID)			UUID unique créé
2	Calcule signature HMAC-SHA256 du payload			Signature prête
3	POST /api/inter-wallet/trans fer →	→ TLS chiffré →		Requête reçue
4			Recalcule HMAC-SHA256, compare à metadata.signature	
4a			✓ Signature valide → étape 5	Intégrité confirmée
4b			✗ Signature invalid → rejet immédiat 401	Transaction annulée
5			Moteur de fraude : calcul du score de risque	Score calculé
5a			ACCEPTED → crédite wallet destinataire	Exécution immédiate
5b			REVIEW → statut PENDING, attente manuelle	Transaction en attente
5c			BLOCKED → rejet, reason_code FRAUD_RISK_HIG H	Transaction refusée
6			Crée Transactions + InterWalletLogs en base	Persistance assurée
7		← TLS ←	Répond : { valid, status, executed_at }	
8	Met à jour statut local de la transaction			Synchronisation état
9	GET /api/inter-wallet/stat us/{id} (polling optionnel)	→ →	Retourne statut courant	Traçabilité complète

1.2 Comportement spécifique au statut REVIEW

Le statut REVIEW n'était pas explicitement spécifié dans le cahier des charges. Voici la définition contractuelle retenue :

Définition du statut REVIEW

- Wallet B répond à Wallet A avec { valid: true, status: "REVIEW" } et un HTTP 202.
- La transaction est persistée en base avec status = REVIEW et riskStatus = REVIEW.
- Le solde du wallet destinataire N'EST PAS crédité immédiatement.
- Wallet A reçoit le reason_code FRAUD_REVIEW_REQUIRED et affiche un statut "en attente de validation".
- Un opérateur humain examine la transaction dans le dashboard. Il peut la passer à SUCCESS (crédit effectif) ou BLOCKED.
- Wallet A peut interroger GET /api/inter-wallet/status/{id} pour connaître l'état à tout moment.
- Aucun délai maximum n'est défini dans le MVP — ce SLA sera contractualisé en v1 post-MVP.

1.3 Gestion des erreurs et codes retour HTTP

HTTP	Statut transaction	reason_code	Contexte
200	SUCCESS	null	Transaction exécutée avec succès
202	REVIEW	FRAUD_REVIEW_REQUIRED	Transaction mise en attente — analyse manuelle
401	—	INVALID_SIGNATURE	Signature HMAC invalide — rejet avant persistance
402	BLOCKED	INSUFFICIENT_FUNDS	Solde insuffisant côté wallet source
403	BLOCKED	FRAUD_RISK_HIGH	Score de risque au-dessus du seuil de blocage
404	FAILED	INVALID_WALLET	Wallet destinataire introuvable
429	FAILED	LIMIT_EXCEEDED	Fréquence de transactions trop élevée
500	FAILED	PROVIDER_ERROR	Erreur interne Wallet B

2. Spécification du protocole — Format JSON

Source : Section 7 du cahier des charges, consolidée et complétée.

Tous les échanges inter-wallets utilisent exclusivement le format JSON sur HTTPS (TLS obligatoire). Chaque payload doit être signé via HMAC-SHA256 avant transmission.

2.1 Référence complète des champs

Champ	Type	Nullable	Description
transaction_id	string UUID	Non	Identifiant unique de la transaction
provider	string	Non	Identifiant du wallet émetteur (ex : wallet_a)
provider_tx_id	string	Oui	ID chez le fournisseur, null avant confirmation
initiator_user_id	string UUID	Non	Utilisateur à l'origine de l'action
source_wallet_id	string	Non	Wallet débité
destination_wallet_id	string	Non	Wallet crédité
amount	decimal	Non	Montant positif (ex : 150.50)
currency	string ISO 4217	Non	Devise (ex : EUR, USD)
transaction_type	string	Non	P2P MERCHANT CASHIN CASHOUT
direction	string	Non	outgoing (émetteur) incoming (récepteur)
status	string	Non	PENDING SUCCESS FAILED CANCELED REVIEW BLOCKED
reason_code	string	Oui	INSUFFICIENT_FUNDS FRAUD_RISK_HIGH FRAUD_REVIEW_REQUIRED ...
created_at	ISO 8601	Non	Date de création côté émetteur
provider_created_at	ISO 8601	Oui	Date renvoyée par le fournisseur si disponible
executed_at	ISO 8601	Oui	Date d'exécution effective (null avant confirmation)
country	string ISO 3166-1	Non	Code pays (ex : FR, US)
city	string	Oui	Ville via géolocalisation IP/GPS
description	string	Oui	Libellé libre (ex : remboursement, loyer)
metadata.raw_provider_payload	object	Oui	Payload brut du fournisseur (audit, conformité)
metadata.signature	string	Non	Signature HMAC-SHA256 du payload complet

2.2 Exemple de payload complet

POST /api/inter-wallet/transfer — Payload exemple

```
{
  "transaction_id": "550e8400-e29b-41d4-a716-446655440000",
  "provider": "wallet_a",
  "provider_tx_id": null,
  "initiator_user_id": "user_123",
  "source_wallet_id": "wallet_alice_001",
  "destination_wallet_id": "wallet_bob_002",
  "amount": 150.50,
  "currency": "EUR",
  "transaction_type": "P2P",
  "direction": "outgoing",
  "status": "PENDING",
  "reason_code": null,
  "created_at": "2025-01-15T10:30:00Z",
  "provider_created_at": "2025-01-15T10:30:01Z",
  "executed_at": null,
  "country": "FR",
  "city": "Paris",
  "description": "Remboursement dîner",
  "metadata": {
    "raw_provider_payload": { "bank_reference": "REF_12345" },
    "signature": "hmac_sha256_hash_of_payload"
  }
}
```

3. Endpoints du protocole inter-wallets

Source : Section 7 et Annexe B du cahier des charges, consolidées.

POST `/api/inter-wallet/transfer` — Initier un transfert depuis Wallet A

Sens	Champ	Valeur / Description
Request	transaction_id	UUID unique de la transaction
Request	source_wallet_id	Identifiant du wallet émetteur
Request	destination_wallet_id	Identifiant du wallet récepteur
Request	amount	Montant positif en decimal
Request	currency	ISO 4217 (ex : EUR)
Request	description	Libellé libre (optionnel)
Request	metadata.signature	HMAC-SHA256 du payload complet
Response	transaction_id	UUID de la transaction créée
Response	status	PENDING SUCCESS REVIEW BLOCKED
Response	message	Description lisible du résultat

POST `/api/inter-wallet/validate` — Wallet B confirme ou rejette une transaction reçue

Sens	Champ	Valeur / Description
Request	transaction_id	UUID de la transaction à valider
Request	signature	HMAC-SHA256 du payload de validation
Response	valid	boolean — true si signature correcte et traitement OK
Response	status	SUCCESS REVIEW BLOCKED
Response	executed_at	ISO 8601 si exécutée, null sinon

GET `/api/inter-wallet/status/{transaction_id}` — Consulter le statut courant d'une transaction

Sens	Champ	Valeur / Description
Response	transaction_id	UUID de la transaction
Response	status	PENDING SUCCESS REVIEW BLOCKED FAILED CANCELED
Response	executed_at	ISO 8601 si exécutée, null sinon
Response	reason_code	Code d'erreur si applicable, null sinon

4. Moteur de détection de fraude — MVP

Source : Sections 3, 6 et Lot 4 bis du cahier des charges, consolidées.

Le moteur de fraude du MVP repose sur un ensemble de règles métier explicites combinées à un scoring numérique. Ce choix délibéré garantit une explicabilité totale des décisions et une implémentation rapide, sans dépendance à des modèles d'apprentissage automatique.

4.1 Règles et décisions

Règle analysée	Critère	Score de risque	Décision
Montant de la transaction	Montant > seuil configuré	Élevé	REVIEW ou BLOCKED
Type de transaction	CASHOUT ou MERCHANT à fort montant	Moyen à élevé	REVIEW
Historique du wallet	Wallet récent sans historique	Moyen	REVIEW
Fréquence des transactions	Nb de transactions > seuil / heure	Élevé	BLOCKED
Score composite	Score < seuil bas	Faible	ACCEPTED
Score composite	Seuil bas ≤ score < seuil haut	Moyen	REVIEW
Score composite	Score ≥ seuil haut	Élevé	BLOCKED

4.2 Intégration au flux de traitement

- Le moteur est appelé APRÈS validation de la signature HMAC-SHA256 et AVANT tout crédit en base.
- Il s'applique identiquement aux transactions locales et inter-wallets.
- Le score de risque et la décision sont persistés dans les champs riskScore et riskStatus de la table Transactions.
- Une transaction BLOCKED génère un reason_code FRAUD_RISK_HIGH retourné à Wallet A.
- Une transaction REVIEW génère un reason_code FRAUD_REVIEW_REQUIRED et reste en attente.

5. Schéma de données concerné

Source : Annexe A du cahier des charges (schéma Prisma), extraits pertinents au protocole inter-wallets.

5.1 Table Transactions

Champ	Type Prisma	Nullable	Description
id	String (cuid)	Non	Identifiant unique de la transaction
fromWalletId	String	Non	Wallet débité (clé étrangère → Wallets)
toWalletId	String	Non	Wallet crédité (clé étrangère → Wallets)
amount	Decimal	Non	Montant de la transaction
currency	String	Non	Devise ISO 4217 (défaut : EUR)
status	String	Non	PENDING SUCCESS FAILED CANCELED REVIEW BLOCKED
transactionType	String	Non	P2P MERCHANT CASHIN CASHOUT (défaut : P2P)
description	String?	Oui	Libellé libre
riskScore	Int?	Oui	Score de risque calculé par le moteur de fraude
riskStatus	String?	Oui	ACCEPTED REVIEW BLOCKED
createdAt	DateTime	Non	Date de création (défaut : now())
executedAt	DateTime?	Oui	Date d'exécution effective, null avant confirmation

5.2 Table InterWalletLogs

Champ	Type Prisma	Nullable	Description
id	String (cuid)	Non	Identifiant unique du log
transactionId	String	Non	Référence vers la transaction principale
fromWallet	String	Non	Identifiant du wallet émetteur
toWallet	String	Non	Identifiant du wallet récepteur
status	String	Non	Statut final de l'échange inter-wallets
signatureVerified	Boolean	Non	true si la signature HMAC-SHA256 a été validée
rawPayload	Json?	Oui	Payload brut reçu (audit, conformité, débogage)
createdAt	DateTime	Non	Date de création du log (défaut : now())

6. Sécurité du protocole

Source : Sections 4 et 6 du cahier des charges, extraits relatifs aux échanges inter-wallets.

Mécanisme	Mise en oeuvre	Couverture
Signature HMAC-SHA256	Calculée sur le payload complet avant envoi, vérifiée en premier côté récepteur	Intégrité des messages
TLS (HTTPS obligatoire)	Chiffrement de tous les échanges en transit	Confidentialité des données
JWT côté API locale	Sécurisation des endpoints /api/* internes	Accès aux ressources
Moteur de fraude	Score de risque + décision automatique avant exécution	Détection des transactions frauduleuses
Audit trail (InterWalletLogs)	Persistance de chaque échange avec signatureVerified et rawPayload	Traçabilité et conformité
Validation des payloads	Contrôles systématiques des champs entrants (Zod / Joi)	Intégrité des données entrantes

Hors périmètre MVP — roadmap post-v1

- Chiffrement au repos des données sensibles
- SIEM et supervision centralisée
- Rotation automatique des clés HMAC
- Détection de fraude avancée (machine learning, scoring comportemental)